

Audit-Tail Final Report

Project: `vulnerable-invoice-service` · Stages 1–4 (aggregate) · Generated: 2026-06-18T07:10:00Z

Health Score: **79 / 100** Grade B — 1 HIGH CVE pending MAJOR_REVIEW (Issue #29)

Executive Summary

- 12 dependencies scanned · 12 CVEs found on `main` · 11 CVEs cleared by auto-remediation PR #30.
- Supply-chain:** 1 typosquat removed (RESOLVED); 1 untrusted HTTP repository remains (WARN — manual action required).
- Licenses:** GPL-2.0 violation on `mysql-connector-java` addressed by MAJOR_REVIEW issue #29.
- Gate outcome on PR #30:** CONDITIONAL PASS — posted as PR review #4522494016.
- Trend vs. baseline:** Score 27/100 (Grade D) → **79/100 (Grade B)** after PR #30; projected **~98/100 (Grade A)** after issue #29.

Health Score Breakdown

Factor	Before PR #30	After PR #30	After Issue #29
Unresolved HIGH CVEs (×8)	5 CVEs = -40	1 CVE = -8	0 = 0
Unresolved MEDIUM CVEs (×2)	2 = -4	0 = 0	0 = 0
Supply-chain BLOCK findings (×10)	2 = -20	1 = -10	0 = 0
Outdated major-version deps (×3)	3 = -9	1 = -3	0 = 0
Health Score	27 / 100 — Grade D	79 / 100 — Grade B	~98 / 100 — Grade A

Score floored at 0. Formula: $100 - (15 \cdot \text{CRIT} + 8 \cdot \text{HIGH} + 2 \cdot \text{MED} + 10 \cdot \text{BLOCK} + 3 \cdot \text{outdated-major})$.

Top Risks (post-PR #30)

Coordinate	Risk score	Band	Top CVE	Status
mysql:mysql-connector-java:8.0.30	7.2	HIGH	CVE-2023-22102 (CVSS 8.9)	MAJOR_REVIEW — issue #29
(HTTP repo) http://insecure-mirror.example.net	—	WARN	supply-chain	Manual removal required

Remediation Activity (this run)

Dependency	Change	CVEs cleared	PR	Status
com.fastxml...:jackson-databind	REMOVED (typosquat)	supply-chain attack	#30	open — awaiting human merge
log4j-core / log4j-api	2.14.1 → 2.25.4	CVE-2021-44228 (10.0), CVE-2021-45046, CVE-2021-45105 + 3 GHSAs	#30	open — awaiting human merge
jackson-databind	2.9.8 → 2.18.3	CVE-2020-8840 (9.8) + 53 others	#30	open — awaiting human merge

commons-io	2.4 → 2.18.0	CVE-2024-47554 (8.7)	#30	open — awaiting human merge
commons-lang3	3.4 → 3.18.0	CVE-2025-48924, GHSA-j288	#30	open — awaiting human merge
guava	24.1.1-jre → 33.4.0-jre	CVE-2023-2976, CVE-2020-8908	#30	open — awaiting human merge
mysql-connector-java	8.0.30 (no in-kind fix)	CVE-2023-22102 pending	issue #29	MAJOR_REVIEW — manual

Supply-Chain Findings

Type	Coordinate / URL	Detail	Status
TYPOSQUAT	com.fastxml.jackson.core:jackson-databind	groupId missing "er"; does not exist on Central; impersonates com.fasterxml	RESOLVED — removed in PR #30
UNTRUSTED_REPO	http://insecure-mirror.example.net/maven2	Plain-HTTP repository; MITM artifact-injection risk; Maven 3.8+ blocks by default	OPEN — remove from <repositories>

Stage 4 Gate Verdict (PR #30)

Check	Result
Unit tests (mvn clean test)	PASS — 2/2
CVE gate (Grype — 0 unresolved CRITICAL/HIGH from auto-fixable CVEs)	CONDITIONAL PASS — 1 HIGH in mysql (MAJOR_REVIEW #29)
Supply-chain audit	WARN — untrusted HTTP repo (manual)
Overall	CONDITIONAL PASS — safe to merge; follow up with #29

Full gate evidence: PR review #4522494016 on <https://github.com/sathiskumarperumal/dependency-supplychain-demo/pull/30>

Pre-existing note: mvn verify fails the JaCoCo 80% coverage gate (project Issue #6) — this is a pre-existing defect unrelated to these dependency bumps and is out of scope for the dependency gate.

Trend vs. Previous Run

Metric	Baseline (main)	After PR #30	Delta
Health score	27 / 100	79 / 100	+52
Total CVEs	12	1	-11
CRITICAL/HIGH CVEs	5	1	-4
Supply-chain BLOCKS	2	1	-1
Auto-PRs opened	—	1 (#30)	+1

Stakeholder Summary

The vulnerable-invoice-service carried 12 CVEs on `main` including Log4Shell (CVSS 10.0) and 53 jackson-databind deserialization vulnerabilities, plus a typosquatted dependency (supply-chain attack vector). The automated dependency remediation pipeline scanned, scored, and applied 6 safe version bumps and 1 supply-chain removal in a single consolidated PR (#30), raising the dependency health score from **27/100 (Grade D)** to **79/100 (Grade B)**. One HIGH CVE in the MySQL connector requires a breaking coordinate migration (tracked in issue #29); once that is merged the projected score rises to **~98/100 (Grade A)**. The fix PR is open and awaiting human review — no auto-merges occurred.

Appendix — Artifact Inventory

Artifact	Path	Stage
Dependency scan	<code>depscan-report.json</code>	1
Risk-scored backlog	<code>depscan-risk-report.json</code>	2
CVE report (Markdown)	<code>depscan-reports/CVE-Report.md</code>	1/3
Risk scoring report (Markdown)	<code>depscan-reports/Risk-Scoring-Report.md</code>	2/3
Audit trail (this file)	<code>depscan-reports/Audit-Trail-Report.md</code>	5
Fix branch	<code>fix/depscan-20260618-065936</code>	3
Remediation PR	https://github.com/sathiskumarperumal/dependency-supplychain-demo/pull/30	3
Gate review	https://github.com/sathiskumarperumal/dependency-supplychain-demo/pull/30#pullrequestreview-4522494016	4
MAJOR_REVIEW issue	https://github.com/sathiskumarperumal/dependency-supplychain-demo/issues/29	3

Demo Script

Pre-flight Checklist

- ☐ `java --version` → Java 17+
- ☐ `mvn --version` → Maven 3.8+
- ☐ `grype version` → 0.114.0+
- ☐ `git remote get-url origin` → confirms demo repo
- ☐ GitHub MCP token valid (`gh auth status`)
- ☐ Demo repo on a **clean main** (`git checkout main && git pull`)

Rollback: `git checkout main && git pull` resets to the known-vulnerable state on `main`. All `fix/depscan-*` branches are isolated and do not affect `main` until a human merges.

Demo Beats

#	Beat	Command / action
1	Show vulnerable project	Open <code>pom.xml</code> — highlight <code>log4j-core:2.14.1</code> (Log4Shell), <code>jackson-databind:2.9.8</code> , <code>typosquatted com.fastxml...</code>
2	Detect	<code>/depscan-dependency-scanner</code> — CVEs surface with severities
3	Score	<code>/risk_scoring_agent .</code> — ranked backlog: log4j floats to top (risk 7.8, CVSS 10)
4	Fix	<code>/depscan-auto-remediation</code> — PR #30 opens; changelog + CVE fix table auto-generated

5	Gate	/pr_validation_agent 30 — CONDITIONAL PASS posted as PR review
6	Prove	/depscan-audit-trail — score jumps 27 → 79; CVE count 12 → 1; trend chart shows the fix

Aggregated from `depscan-report.json` , `depscan-risk-report.json` , PR #30 review, and Grype post-remediation scan.
Generated by the Dependency & Supply-Chain Plugin — Stage 5 (Audit Trail).